

Brute Force & Suspicious Access Investigation

By: Adam Mohmoud

Lab Objective:

Investigate suspicious login behavior on a web application server using Splunk. Detect brute force attempts, successful logins after multiple failures, external vs internal access, and visualize patterns via dashboards.

Step 1: Validate uploaded data of 'web_auth.log'

Once the web_auth.log file was uploaded into Splunk, the first step in the investigation was to validate that the data ingested correctly. This ensures that all log lines are accessible, and that the basic fields such as timestamps, usernames, IP addresses, and login statuses are visible before further analysis.

</> SPL

index=main

| head 20

New Search

index=main
| head 20

#	Time	Event
1	2/27/2020 8:56:48.037 AM	LogName=Application EventCode=10204 EventTypeId=4 ComputerName=Endurance08 SourceName=C:\Program Files\Windows Security\WSP Type=Information SourceName=Winlog Keywords=Classic TaskCategory=None OpCode=None Message=Successfully scheduled Software Protection service for re-start at 2/26-82-40713-58-432. Reason: RuleEngine. C:\Users
2	2/27/2020 8:56:48.037 AM	LogName=Application EventCode=10204 EventTypeId=4 ComputerName=Endurance08 Show all 12 lines
3	2/27/2020 8:56:48.037 AM	LogName=Application EventCode=10204 EventTypeId=4 ComputerName=Endurance08 Show all 12 lines
4	2/27/2020 8:56:48.037 AM	LogName=Security EventCode=1001 EventTypeId=8 ComputerName=Endurance08 Show all 20 lines
5	2/27/2020 8:56:48.037 AM	LogName=Security EventCode=1001 EventTypeId=8 ComputerName=Endurance08 Show all 33 lines
6	2/27/2020 8:56:48.037 AM	LogName=Security EventCode=1001 EventTypeId=8 ComputerName=Endurance08 Show all 33 lines
7	2/27/2020 8:56:48.037 AM	LogName=Security EventCode=1001 EventTypeId=8 ComputerName=Endurance08 Show all 33 lines

Step 2: Field Extraction

After successfully uploading the web_auth.log file into Splunk, the next critical step is 'field extraction'; which allows the analyst to break down raw log lines into meaningful, searchable components. This is essential for filtering, aggregation, and detection of suspicious activity.

- User - User attempting to login
- Src_ip - Source IP address initiating the login
- Action - Type of activity (login)
- Status - Outcome (Success or Failed)

Step 3: Detect Brute Force Attempts

After validating the log ingestion and extracting fields, the next step in the investigation was to identify brute force login attempts.

Count Failed Logins per IP

I ran the following SPL query to aggregate failed login attempts by source IP:

New Search

```
index=main status=failed
| stats count by src_ip
| sort -count
```

✓ 680 events (before 2/27/26 9:48:03.000 AM) No Event Sampling ▼

Events Patterns **Statistics (5)** Visualization

Show: 20 Per Page ▼  Format ▼  Preview: On

src_ip ↕	count ↕ 
10.0.0.45	139
185.220.101.4	138
192.168.1.15	135
203.0.113.55	135
45.33.32.156	133

Detect Successful Login After Multiple Failures

To detect accounts that were eventually compromised after multiple failed attempts, the SPL to run:

New Search

```
index=main
| stats count(eval(status="failed")) as failures,
           count(eval(status="success")) as successes
  by user src_ip
| where failures >= 3 AND successes >= 1
```

✓ 934,996 events (before 2/27/26 9:59:17.000 AM)

No Event Sampling ▼

Events Patterns Statistics (25) Visualization			
Show: 20 Per Page ▼	Format ▼	Preview: On	< Prev 1 2 Next >
user ↕	src_ip ↕	failures ↕	successes ↕
admin	10.0.0.45	25	18
admin	185.220.101.4	26	12
admin	192.168.1.15	30	17
admin	203.0.113.55	25	11
admin	45.33.32.156	24	7
asmith	10.0.0.45	24	12
asmith	185.220.101.4	31	8
asmith	192.168.1.15	25	10
asmith	203.0.113.55	34	12
asmith	45.33.32.156	30	16
jdoe	10.0.0.45	36	6
jdoe	185.220.101.4	21	11
jdoe	192.168.1.15	21	9
jdoe	203.0.113.55	31	14
jdoe	45.33.32.156	31	17
service_account	10.0.0.45	33	16
service_account	185.220.101.4	28	14
service_account	192.168.1.15	30	10
service_account	203.0.113.55	24	15
service_account	45.33.32.156	25	17

Events Patterns Statistics (25) Visualization			
Show: 20 Per Page ▼	Format ▼	Preview: On	< Prev 1 2 Next >
user ↕	src_ip ↕	failures ↕	successes ↕
unknown	10.0.0.45	21	11
unknown	185.220.101.4	32	15
unknown	192.168.1.15	29	14
unknown	203.0.113.55	21	11
unknown	45.33.32.156	23	17

10.0.0.45 (internal) had multiple failed login attempts (user: asmith).

185.220.101.4 (external) had repeated failures on admin account (brute force sign).

192.168.1.15 is a local IP (user: jdoe), with some failed attempts.

203.0.113.55 and 45.33.32.156 are external IPs with failed logins from unknown or other users.

Step 4: Classify Internal vs External Ips

After detecting brute force attempts, the next step in the investigation was to classify login attempts as **internal** or **external**. This is a critical part of threat hunting, as attacks from external IPs are generally more suspicious than internal logins, while anomalous internal logins can indicate insider threats or compromised accounts.

Run the following SPL query to classify source IP addresses:

```
index=main
| eval ip_type=if(
  cidrmatch("192.168.0.0/16", src_ip) OR
  cidrmatch("10.0.0.0/8", src_ip) OR
  cidrmatch("172.16.0.0/12", src_ip),
  "internal", "external")
| stats count by ip_type
```

✓ 935,651 events (before 2/27/26 11:21:14.000 AM) No Event Sampling ▼

Events Patterns **Statistics (2)** Visualization

Show: 20 Per Page ▼ ↗ Format ▼ ☒ Preview: On

ip_type ↕

external

internal

Step 5: Identify Suspicious External Logins

After classifying IP addresses as internal or external, the next phase of the investigation focused on identifying successful login attempts originating from external IP addresses.

Successful authentication from an external source can indicate:

- Legitimate remote access
- Credential reuse
- Compromised credentials
- Successful brute force attack

The following SPL query was used to isolate successful login events and classify their source IP as internal or external:

New Search

```
index=main source="*web_auth.log" status=success
| eval ip_type=if(
  cidrmatch("192.168.0.0/16", src_ip) OR
  cidrmatch("10.0.0.0/8", src_ip) OR
  cidrmatch("172.16.0.0/12", src_ip),
  "internal","external")
| search ip_type="external"
| table _time user src_ip status
| sort -_time
```

✓ 197 events (before 2/27/26 12:41:12.000 PM) No Event Sampling

Events Patterns **Statistics (197)** Visualization

Show: 20 Per Page ▾  Format ▾  Preview: On

				< Prev		1	2	3	4	5	6
user ↕		src_ip ↕									
asmith		45.33.32.156									
service_account		45.33.32.156									
unknown		203.0.113.55									
asmith		185.220.101.4									
jdoe		45.33.32.156									
unknown		45.33.32.156									
jdoe		45.33.32.156									
asmith		45.33.32.156									
admin		185.220.101.4									
jdoe		185.220.101.4									

Outcome and Observations

- Successful login attempts were identified from external IP addresses.
- Notably, the admin account showed successful authentication from an external IP following multiple failed login attempts.
- This pattern strongly suggests a successful brute force attack scenario.

Additionally:

- Other user accounts (ex. jdoe) showed external successful logins without prior failures, which may indicate credential reuse or previously compromised credentials.

- These findings highlight the importance of correlating authentication success events with preceding failures.

Risk Assessment:

These successful external logins represent elevated risk because:

- They originate outside the trusted internal network boundary.
- They may indicate unauthorized access.
- They can precede lateral movement, privilege escalation, or data exfiltration.

Particular attention should be given to:

- Administrative accounts
- Service accounts
- Accounts with elevated privileges

Step 7: Create and Document Alert Configuration

After analyzing login activity and building dashboards, the next step in this SOC investigation was to create an alert to proactively detect suspicious authentication activity.

The objective of this alert is to identify potential brute force attacks in near real-time, enabling faster response and mitigation.

Alert Criteria:

Using `source=*web_auth.log` ensures the alert only monitors my dataset, preventing false positives from other logs in main.

The alert was designed to trigger when:

- More than 5 failed login attempts occur from a single IP
- Within a 5-minute window

This threshold is chosen to balance detection of attacks while avoiding alert fatigue from normal user typos.

The SPL query demonstrates time-based aggregation, conditional filtering, and field-based correlation.

Create Alert



Settings

Title Brute Force Detection Alert

Description Detects >5 failed logins from a single IP within 5 minutes

Search
index=main source="*web_auth.log" status=failed
| bin _time span=5m
| stats count by src_ip _time
| where count > 5

App Search & Reporting (search) ▼

Permissions Private Shared in App

Alert type Scheduled Real-time

Expires 0 hour(s) ▼

Trigger Conditions

Trigger alert when Per-Result ▼

Throttle ? ☒

Suppress results contain-
ing field value

Suppress triggering for 15 minute(s) ▼

Trigger Actions

+ Add Actions ▼

Cancel

Save